

BÁO CÁO ĐIỀU TRA SỰ CỐ AN NINH MẠNG

INCIDENT RESPONSE REPORT

RDP Brute-Force Attack — Windows Victim Host

Khung tham chiếu: NIST SP 800-61 Rev.2 — Computer Security Incident Handling Guide

SOC / Blue Team Home Lab

Mã sự cố: INC-2026-0716-002

Người lập báo cáo: Nguyễn Minh Khoa

Ngày lập: 16/07/2026

Phân loại: Nội bộ — Lab cá nhân

1. Tóm tắt sự cố (Executive Summary)

Vào ngày 16/07/2026, hệ thống giám sát Splunk SIEM trong lab SOC/Blue Team đã phát hiện nhiều đợt tấn công dò mật khẩu (brute-force) nhắm vào dịch vụ Remote Desktop Protocol (RDP) của máy Windows victim (192.168.54.20). Nguồn tấn công được xác định là máy Kali Linux (192.168.54.40), sử dụng công cụ Hydra để dò mật khẩu tài khoản "khoa" qua cổng 3389.

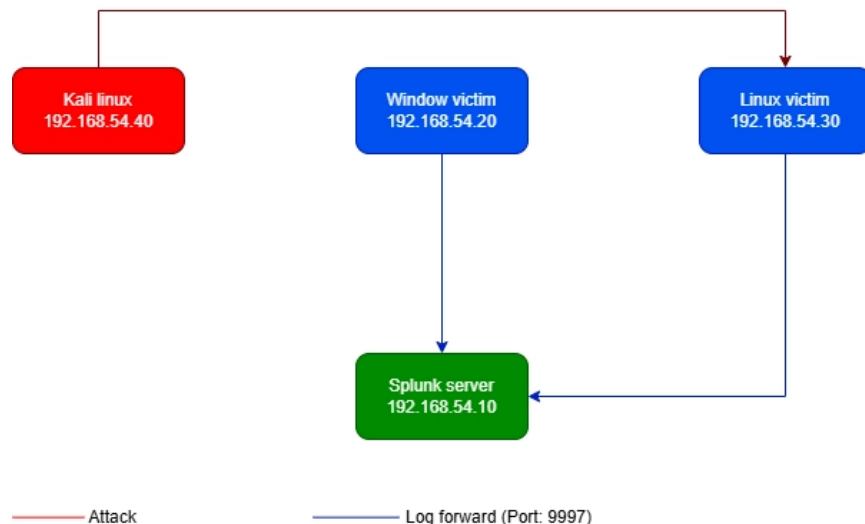
Trong quá trình tấn công, cơ chế bảo vệ mặc định của Windows (Account Lockout Policy) đã tự động kích hoạt, khóa tài khoản "khoa" sau mỗi đợt vượt ngưỡng đăng nhập sai — một hình thức containment tự động ở tầng hệ điều hành, xảy ra trước cả khi SOC analyst can thiệp thủ công. Cảnh báo tự động (RDP Brute Force Alert) trên Splunk cũng được kích hoạt song song, xác nhận khả năng phát hiện đầy đủ của hệ thống giám sát. Báo cáo này trình bày toàn bộ quá trình phát hiện, phân tích, và các bước xử lý theo khung NIST SP 800-61.

Mã sự cố	INC-2026-0716-002
Loại sự cố	Brute-force / Credential Access (MITRE ATT&CK T1110.001)
Mức độ nghiêm trọng	Trung bình (Medium)
Hệ thống bị ảnh hưởng	Windows victim — 192.168.54.20 (dịch vụ RDP, cổng 3389)
Nguồn tấn công (IOC)	192.168.54.40 (Kali Linux)
Tài khoản mục tiêu	khoa
Công cụ phát hiện	Splunk Enterprise 10.4.1 — SPL detection + Scheduled Alert (cron 5 phút)
Trạng thái xử lý	Đã xác nhận qua log, đã có alert tự động; đã xác minh KHÔNG có đăng nhập thành công; đã ghi nhận auto-containment ở tầng OS (Account Lockout)

2. Chuẩn bị (Preparation)

Trước khi xảy ra sự cố, hạ tầng giám sát đã được chuẩn bị với các thành phần sau:

- Splunk Enterprise được triển khai trên Ubuntu Server (192.168.54.10), đóng vai trò SIEM trung tâm.
- Splunk Universal Forwarder được cài trên Windows victim, forward Windows Security Event Log (kênh WinEventLog://Security) về index "wineventlog" qua cổng 9997, song song với kênh Sysmon đã cấu hình từ trước.
- Toàn bộ hệ thống trong lab được đồng bộ thời gian (NTP qua chrony/w32time) và thống nhất múi giờ Asia/Ho_Chi_Minh (UTC+7), đảm bảo timestamp giữa các nguồn log khớp nhau chính xác.
- Một luật phát hiện SPL và Alert dạng Scheduled (chạy mỗi 5 phút qua cron) đã được cấu hình sẵn để phát hiện các chuỗi đăng nhập RDP thất bại bất thường.
- Toàn bộ hệ thống được cô lập trong mạng Host-only VirtualBox (192.168.54.0/24), phục vụ mục đích thực hành, không ảnh hưởng hệ thống thật.



Hình 1 — Sơ đồ kiến trúc lab: luồng tấn công (đỏ) và luồng forward log (xanh) về Splunk server.

3. Phát hiện & Phân tích (Detection & Analysis)

3.1. Ghi nhận tấn công tại nguồn

Tại máy attacker (Kali Linux), công cụ Hydra được sử dụng để dò mật khẩu RDP nhắm vào 192.168.54.20. Trong quá trình tấn công, Hydra liên tục gặp lỗi "too many connection errors" — nguyên nhân được xác định là do Windows bật Network Level Authentication (NLA), khiến mỗi lượt thử password phải thiết lập lại toàn bộ phiên CredSSP, dễ bị timeout. Sau khi vô hiệu hóa NLA để phục vụ mục đích thử nghiệm, một điều bất ngờ được ghi nhận: chỉ sau một loạt các lượt thử ban đầu, tài khoản "khoa" đã bị khóa tự động bởi chính sách bảo mật mặc định của Windows, thể hiện qua lỗi xác thực khi kết nối thủ công bằng xfreerdp:

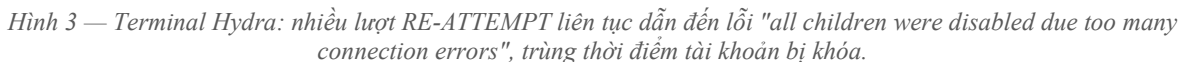
```
[ERROR][com.freerdp.core] - [nla_recv_pdu]: ERRCONNECT_ACCOUNT_LOCKED_OUT [0x00020018]
[WARN][com.freerdp.crypto] - Certificate verification failure 'self-signed certificate (18)'
```

```

(kali@kali)~$ xfreerdp /v:192.168.54.20 /u:khoa
[22:42:16:684] [97674:00017d8c] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]: : keycode: 0x08 → no RDP scancode found
[22:42:16:685] [97674:00017d8c] [WARN][com.freerdp.client.x11] - [load_map_from_xkbfile]: ZEHA: keycode: 0x5d → no RDP scancode found
[22:42:16:737] [97674:00017d8c] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x558a65d8bf70]: *****
[22:42:16:737] [97674:00017d8c] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x558a65d8bf70]: This build is using [experimental] build
options:
[22:42:16:737] [97674:00017d8c] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x558a65d8bf70]: * 'WITH_VAAPI_H264_ENCODING=ON'
[22:42:16:737] [97674:00017d8c] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x558a65d8bf70]: *
[22:42:16:737] [97674:00017d8c] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x558a65d8bf70]: [experimental] build options might crash
the application
[22:42:16:737] [97674:00017d8c] [WARN][com.freerdp.core.rdp] - [log_build_warn][0x558a65d8bf70]: *****
[22:42:16:838] [97674:00017d8c] [WARN][com.freerdp.crypto] - [verify_cb]: Certificate verification failure 'self-signed certificate (18)'
at stack position 0
[22:42:16:839] [97674:00017d8c] [WARN][com.freerdp.crypto] - [verify_cb]: CN = Window-victim
[22:42:16:840] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [xs09_utils_from_pem]: B10_new failed for certificate
[22:42:16:840] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: @
WARNING: CERTIFICAT
E NAME MISMATCH! @
[22:42:16:840] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: @
WARNING: CERTIFICAT
E NAME MISMATCH! @
[22:42:16:840] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: The hostname used for this conn
ection (192.168.54.20:3389)
[22:42:16:840] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: does not match the name given i
n the certificate:
[22:42:16:840] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: Common Name (CN):
[22:42:16:840] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: Window-victim
[22:42:16:840] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: A valid certificate for the wro
ng name should NOT be trusted!
[22:42:16:841] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_new_certificate_warn]: The host key for 192.168.54.20:3389 has ch
anged
[22:42:16:841] [97674:00017d8c] [ERROR][com.freerdp.crypto] - [tls_print_new_certificate_warn]: @
WARNING: REMOTE HOST IDENTIFICATION H
AS CHANGED! @

```

Đây là bằng chứng cho thấy chính sách khóa tài khoản mặc định của Windows (khóa sau 10 lần đăng nhập sai trong 10 phút) đã tự động kích hoạt như một lớp containment đầu tiên, trước khi bất kỳ hành động thủ công nào từ phía SOC analyst được thực hiện. Sau khi mở khóa tài khoản để tiếp tục thử nghiệm, nhiều đợt tấn công Hydra tiếp theo đã được thực hiện, mỗi đợt đều lặp lại chu kỳ: dò mật khẩu → vượt ngưỡng → tài khoản tự khóa.



Log Windows Security Event (Event ID 4625 — An account failed to log on) được forward về Splunk qua Universal Forwarder, index "wineventlog". Một điểm kỹ thuật cần lưu ý: field Account_Name trong Event 4625 là multivalue (chứa cả SubjectUserName rỗng và TargetUserName thật), cần dùng hàm mvindex để trích xuất đúng giá trị trước khi thống kê, tránh đếm trùng lặp:

Trang 4 / 10

The screenshot shows the Splunk Enterprise interface with a search bar containing the following SPL query:

```
index=wineventlog EventCode=4624
| eval target_user=replace(Account_Name, ",")
| bin _time 5min
| stats count as failed_attempts by Source_Network_Address, target_User, _time
| where failed_attempts > 5
| sort - failed_attempts
```

The search results table displays 54 events. The table has columns: Source_Network_Address, target_User, _time, and failed_attempts. The data shows 5 distinct source IP addresses (all 192.168.54.40) each with 7 failed attempts for the user 'khoa' at different times.

Source_Network_Address	target_User	_time	failed_attempts
192.168.54.40	khoa	2026-07-16 08:52:00	13
192.168.54.40	khoa	2026-07-16 09:06:00	10
192.168.54.40	khoa	2026-07-16 09:40:00	10
192.168.54.40	khoa	2026-07-16 09:17:00	7
192.168.54.40	khoa	2026-07-16 11:14:00	7

Hình 4 — Kết quả SPL sau khi sửa lỗi multivalue field: 5 khung 1-phút vượt ngưỡng, dữ liệu sạch, không còn đếm trùng.

Kết quả cho thấy 5 đợt bùng phát tấn công riêng biệt, đều xuất phát từ nguồn 192.168.54.40 nhắm vào tài khoản "khoa":

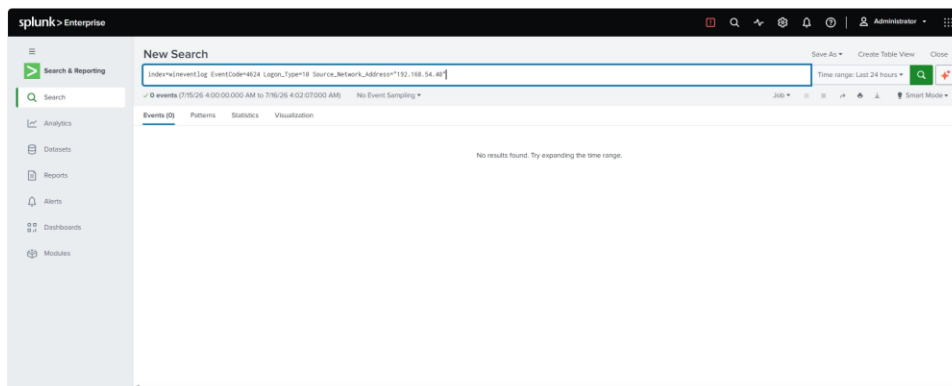
Nguồn (src_ip)	Tài khoản	Thời điểm (bin 1 phút)	Số lượt thất bại
192.168.54.40	khoa	2026-07-16 08:52:00	13
192.168.54.40	khoa	2026-07-16 09:06:00	10
192.168.54.40	khoa	2026-07-16 09:40:00	10
192.168.54.40	khoa	2026-07-16 09:17:00	7
192.168.54.40	khoa	2026-07-16 11:14:00	7

Đáng chú ý, số lượt thất bại mỗi đợt tương đối thấp (7–13 lần) so với kịch bản SSH trước đó (lên đến 286 lần/phút) — điều này phản ánh đúng đặc tính của RDP: giao thức nặng hơn SSH, tốc độ thử tối đa của Hydra bị giới hạn (chỉ chạy được với $-t 1$), đồng thời tài khoản liên tục bị khóa sau mỗi ~10 lần thử, buộc kẻ tấn công phải dừng và chờ (hoặc SOC analyst mở khóa thủ công trong quá trình thử nghiệm) trước khi tiếp tục.

3.3. Xác minh không có đăng nhập thành công

Truy vấn xác minh được thực hiện nhằm tìm sự kiện đăng nhập RDP thành công (Event ID 4624, Logon Type 10 = RemoteInteractive) từ nguồn tấn công:

```
index=wineventlog EventCode=4624 Logon_Type=10 Source_Network_Address="192.168.54.40"
```



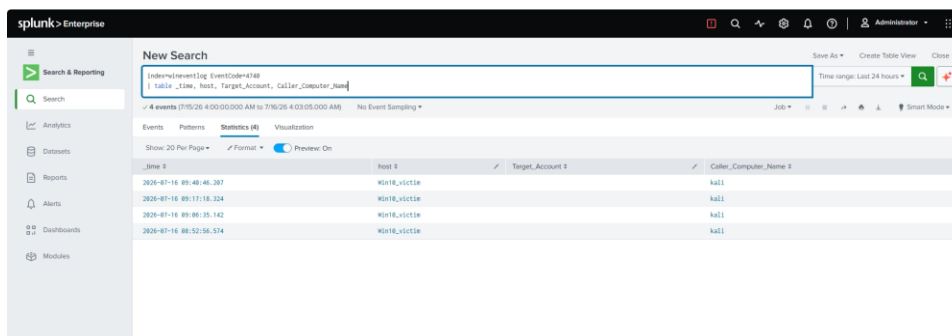
Hình 5 — Kết quả 0 events: không có đăng nhập RDP thành công nào từ nguồn tấn công trong suốt quá trình theo dõi.

Kết quả trả về 0 sự kiện — xác nhận không có bất kỳ lượt đăng nhập RDP thành công nào từ 192.168.54.40, loại trừ khả năng tài khoản "khoa" đã bị xâm nhập qua RDP trong đợt tấn công này.

3.4. Bằng chứng auto-containment (Account Lockout — Event ID 4740)

Một nguồn log bổ sung, đặc trưng riêng cho kịch bản RDP so với SSH, là Event ID 4740 (A user account was locked out), ghi nhận chính xác thời điểm chính sách bảo mật Windows tự động khóa tài khoản:

```
index=wineventlog EventCode=4740
| table _time, host, Target_Account, Caller_Computer_Name
```



Hình 6 — 4 sự kiện Account Lockout ghi nhận trong Splunk, trường `Caller_Computer_Name` xác định rõ nguồn gây khóa là máy "kali".

Thời điểm các sự kiện khóa tài khoản trùng khớp gần như tuyệt đối với thời điểm kết thúc mỗi đợt bùng phát tấn công ở mục 3.2, xác nhận mối liên hệ nhân-quả rõ ràng: mỗi đợt Hydra chạy đủ số lần thử đã kích hoạt khóa tài khoản, tự động cắt đứt đợt tấn công đó.

3.5. Cảnh báo tự động (Alert)

Một Alert dạng Scheduled ("RDP brute force alert") được cấu hình chạy mỗi 5 phút (cron: `*/5 * * * *`), với Time range khớp "Last 5 minutes" và điều kiện trigger "Number of Results is greater than 0" — đảm bảo chỉ cần phát hiện ít nhất 1 khung-phút bất thường trong 5 phút gần nhất là đủ để cảnh báo, đồng thời tránh việc quét lại toàn bộ lịch sử gây lặp vô hạn.

Edit alert

Alert title
RDP brute force alert

Description

Schedule & trigger conditions Trigger actions

* Alert type
Scheduled Real-time

* Schedule
Run On Cron Schedule Cron Expression
*/5 ***
e.g. 0 18 * * * (every day at 6PM) [Learn more](#)

* Time range
Last 5 minutes

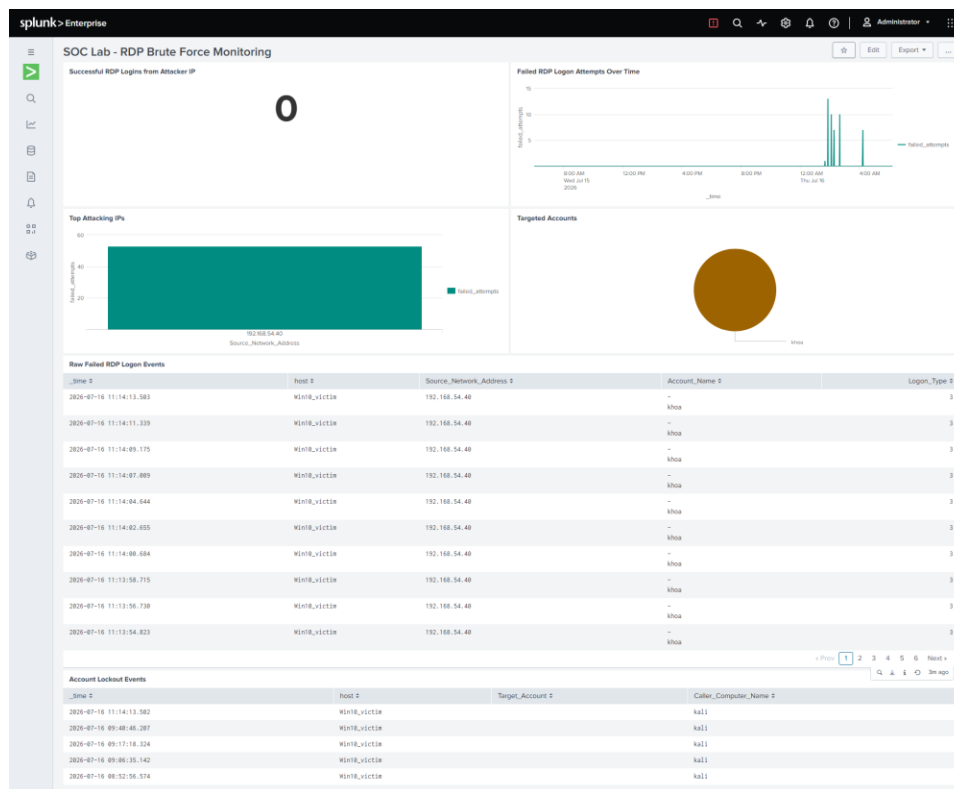
Expires after
24 hour(s)

* Trigger alert when
Number of results is greater than 0

Cancel Save

Hình 7 — Cấu hình Alert: Scheduled, cron 5 phút, Time range = Last 5 minutes, Trigger khi Number of Results > 0.

Hành động khi trigger bao gồm "Add to Triggered Alerts" và "Send Email" tới hộp thư của người quản trị, mô phỏng đúng quy trình một SOC analyst thực tế sẽ nhận được khi có sự cố.



Hình 8 — Dashboard giám sát tổng hợp "SOC Lab - RDP Brute Force Monitoring": xác nhận 0 đăng nhập thành công, timeline các đợt tấn công, top nguồn tấn công, tài khoản bị nhắm tới, và danh sách sự kiện khóa tài khoản.

4. Ngăn chặn (Containment)

Khác với kịch bản SSH trước đó, sự cố này có một lớp containment đã tự động xảy ra ở tầng hệ điều hành (xem mục 3.4). Các bước ngăn chặn bổ sung được khuyến nghị:

- Ghi nhận containment tự động: chính sách Account Lockout của Windows đã hoạt động đúng như thiết kế, tự khóa tài khoản sau mỗi đợt vượt ngưỡng — không cần can thiệp thêm ở lớp này.
- Chặn bổ sung ở tầng mạng: cấu hình Windows Firewall chặn địa chỉ IP nguồn 192.168.54.40 trên cổng 3389 để ngăn các đợt tấn công tiếp theo trước khi tài khoản kịp bị khóa lại.
- Giữ nguyên trạng thái khóa tài khoản trong thời gian điều tra, không mở khóa vội nếu nghi ngờ tiếp tục bị nhắm tới.
- Không tắt dịch vụ RDP hoàn toàn trong quá trình điều tra để tránh làm gián đoạn các truy cập hợp lệ khác (nếu môi trường có nhiều người dùng thật).

5. Khắc phục & Khôi phục (Eradication & Recovery)

5.1. Khắc phục (Eradication)

- Đã xác minh qua log (mục 3.3, Hình 5): không có sự kiện đăng nhập RDP thành công từ nguồn tấn công — hệ thống chưa bị xâm nhập, không cần thực hiện các bước xử lý hậu-xâm nhập.
- Dù chưa bị xâm nhập, khuyến nghị đổi mật khẩu tài khoản "khoa" sang mật khẩu mạnh hơn như biện pháp phòng ngừa.

- Xem xét thay thế xác thực mật khẩu bằng chứng chỉ/smart card hoặc bật lại NLA (đã tắt tạm thời cho mục đích thử nghiệm) — NLA giúp giảm tải tấn công brute-force vì yêu cầu xác thực trước khi thiết lập phiên đầy đủ.

5.2. Khôi phục (Recovery)

- Mở khóa tài khoản "khoa" sau khi xác nhận môi trường an toàn và không còn dấu hiệu tấn công tiếp diễn.
- Bật lại Network Level Authentication (NLA) trên Windows victim để khôi phục mức bảo mật RDP tiêu chuẩn.
- Gỡ bỏ rule chặn IP tạm thời (áp dụng cho lab; môi trường thật cần đánh giá kỹ trước khi gỡ).
- Xác nhận Alert và Dashboard hoạt động ổn định, tiếp tục giám sát trong 24–48 giờ tiếp theo để đảm bảo không có đợt tấn công tái diễn.

6. Bài học kinh nghiệm & Hành động tiếp theo (Lessons Learned)

- Chính sách Account Lockout mặc định của Windows là một lớp phòng thủ hiệu quả, tự động containment ngay cả khi chưa có SOC analyst nào theo dõi trực tiếp — nên được xem là một control quan trọng cần giữ nguyên (không tắt) trên các hệ thống thật.
- Cần cẩn trọng khi thử nghiệm brute-force trên RDP: việc tắt NLA để phục vụ test có thể vô tình làm giảm bảo mật thật của hệ thống nếu quên bật lại — nên ghi chú rõ và có checklist khôi phục cấu hình sau khi test.
- Field multivalue trong Windows Event Log (như Account_Name ở Event 4625) là một cạm bẫy phổ biến khi viết SPL — cần luôn kiểm tra cấu trúc field trước khi viết luật phát hiện chính thức, tránh sai số liệu trong báo cáo.
- Đồng bộ thời gian (NTP) và thống nhất múi giờ giữa các máy trong lab là điều kiện tiên quyết để đối chiếu timeline chính xác giữa nhiều nguồn log — bài học này áp dụng chung cho mọi kịch bản, không riêng RDP.
- Cấu hình Alert dạng Scheduled với Time range khớp đúng chu kỳ cron (thay vì "All time") là bắt buộc để tránh alert bị trigger lặp lại vô hạn trên dữ liệu lịch sử cũ.
- Cần nhắc triển khai RDP Gateway hoặc giới hạn truy cập RDP chỉ qua VPN trong môi trường thật, thay vì mở trực tiếp cổng 3389 ra ngoài — giảm đáng kể diện tấn công (attack surface).

7. Phụ lục — Danh mục minh chứng (Appendix)

Hình	Nội dung	Nguồn
Hình 1	Sơ đồ kiến trúc lab	Vẽ thủ công (draw.io)
Hình 2	xfreerdp — xác nhận chứng chỉ TLS và lỗi ACCOUNT_LOCKED_OUT	Kali Linux
Hình 3	Terminal Hydra — nhiều lượt RE-ATTEMPT dẫn đến lỗi kết nối	Kali Linux
Hình 4	Kết quả SPL sau khi sửa lỗi multivalue field (mindex)	Splunk Search & Reporting

Hình	Nội dung	Nguồn
Hình 5	Truy vấn xác minh Event 4624 Logon Type 10 — 0 events	Splunk — index=wineventlog
Hình 6	Sự kiện Account Lockout (Event ID 4740)	Splunk — index=wineventlog
Hình 7	Cấu hình Alert (RDP brute force alert)	Splunk — Alerts
Hình 8	Dashboard giám sát RDP Brute Force Monitoring	Splunk — Dashboards